

TM: Diseño de Sistema Seguro de Datos Médicos

<https://gemini.google.com/app/108e2b4ece12fbf7>

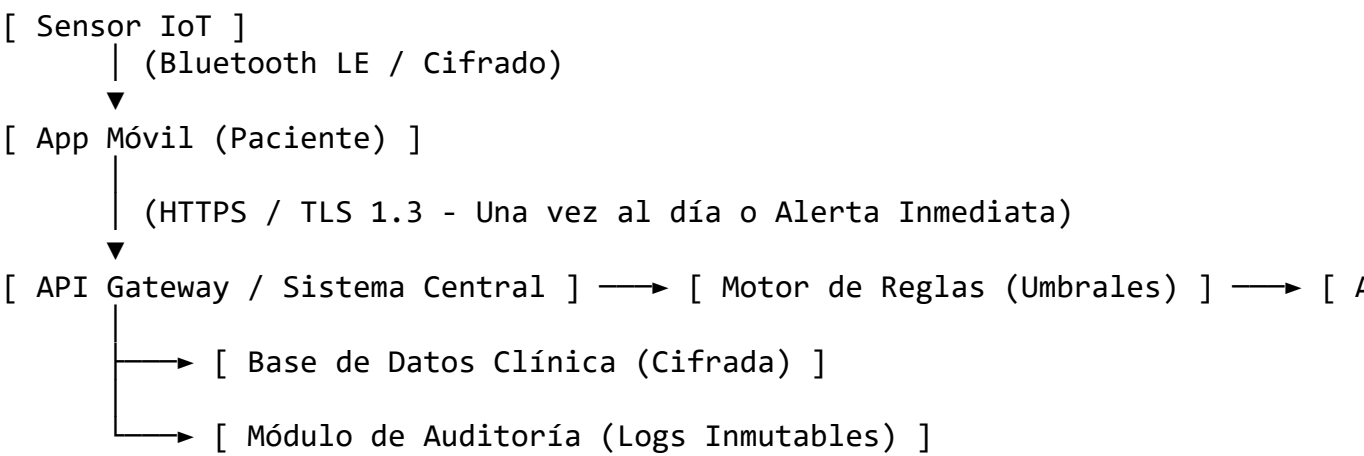
User prompt: Eres un ingeniero de seguridad. Te han encargado el diseño de un sistema de gestión de los datos de un sensor que recoge los niveles de azúcar en sangre. El sensor lo llevan puesto los pacientes en sus casas y envía cada 10 minutos los datos a una aplicación en sus terminales móviles personales. Estos datos se envían una vez al día al hospital del paciente donde se incorporan a su historial clínico. En el hospital, tanto el personal de enfermería como el personal de medicina tiene acceso al historial clínico de los pacientes que tienen asignados. Ten en cuenta los siguientes requisitos que han llegado de los diferentes usuarios: - Como paciente, quiero que sea crítico conservar la confidencialidad de los datos de los pacientes y que solo el personal asignado al paciente (médico o de enfermería) pueda acceder a ellos - Como personal médico, en caso de que los niveles de azúcar en sangre que detecta el sensor superen cierto umbral, quiero que se envíe inmediatamente una alerta a un centro de emergencias. Además, quiero que este umbral solo puede ser establecido por el personal médico, no por el de enfermería - Como director del hospital, quiero que haya un registro de todas las personas que accedan a un historial clínico. Describe los componentes del sistema, identificando los componentes principales y cómo se comunican entre ellos.

Response: ¡Hola! Qué buen reto de arquitectura. Como ingeniero de seguridad, te diré que diseñar un sistema que maneja Datos de Salud Protegidos (PHI, por sus siglas en inglés) requiere aplicar el principio de **defensa en profundidad** y el **principio de menor privilegio**. Estamos hablando de un entorno crítico donde la confidencialidad salva la privacidad, pero la disponibilidad y la integridad salvan vidas.

A continuación, describo los componentes principales del sistema y cómo se comunican entre ellos de forma segura.

1. Arquitectura y Componentes del Sistema

Para cumplir con todos los requisitos, dividiremos el sistema en tres capas: **Dispositivo (Edge)**, **Backend en la Nube/Hospital (Core)** y **Consumidores (Frontend)**.



A. Capa del Paciente (Edge)

- **Sensor IoT (Glucómetro Continuo):** Recoge los niveles de azúcar cada 10 minutos. No tiene gran capacidad de cómputo, por lo que almacena los datos temporalmente de forma

cifrada.

- **Aplicación Móvil Personal:** Actúa como *gateway* local. Recibe los datos del sensor, los almacena localmente en un contenedor seguro (como el *Keychain* o *Keystore* del teléfono) y se encarga de la transmisión.

B. Capa de Control y Lógica (Backend del Hospital)

- **API Gateway y Servicio de Ingesta:** El punto de entrada único para las aplicaciones móviles y los terminales del hospital. Se encarga de la autenticación, autorización y mitigación de ataques (como DDoS).
- **Servicio de Identidad y Acceso (IAM):** El motor que gestiona los roles. Aquí implementaremos un **Control de Acceso Basado en Atributos y Roles (ABAC/RBAC)** para asegurar que un médico o enfermero *solo* vea a los pacientes que tiene explícitamente asignados.
- **Motor de Reglas y Alertas:** Analiza los datos en tiempo real. Si un dato llega y supera el umbral crítico, este componente dispara la alerta sin esperar al volcado diario de datos.

C. Capa de Almacenamiento y Auditoría

- **Base de Datos Clínica (Historial Clínico):** Almacena los datos estructurados. Debe estar cifrada en reposo (*Encryption at Rest*).
- **Módulo de Auditoría y Logs (SIEM):** Un sistema independiente y protegido donde se registra cada lectura, modificación o acceso a los historiales clínicos.

2. Flujo de Comunicación y Mitigación de Riesgos

La comunicación entre estos componentes está diseñada específicamente para cumplir con las peticiones de los usuarios:

Flujo 1: Del Sensor a la App Móvil (Cada 10 minutos)

- **Cómo se comunican:** A través de **Bluetooth Low Energy (BLE)**.
- **Seguridad:** Se implementa un emparejamiento seguro (*Secure Connections*) con cifrado AES-CMAC para evitar ataques de intermediario (*Man-in-the-Middle*).

Flujo 2: De la App Móvil al Hospital (Diario / Inmediato por Alerta)

- **Cómo se comunican:** Conexión **HTTPS** utilizando **TLS 1.3** con *Certificate Pinning* en la app para garantizar que solo hable con el servidor legítimo del hospital.
- **Cumplimiento de Alerta Médica:** Aunque el volcado general de datos es una vez al día, la App Móvil evalúa localmente cada lectura de 10 minutos. Si detecta un valor anómalo (o si el backend procesa la trama y detecta que supera el umbral), se salta la restricción de "una vez al día" y envía un payload de **Alerta Inmediata** al API Gateway, que a su vez contacta al Centro de Emergencias mediante una API prioritaria y cifrada.

Flujo 3: Acceso del Personal Médico y de Enfermería

- **Cómo se comunican:** A través de la red interna del hospital o VPN médica segura hacia el Sistema Central.
- **Cumplimiento de Confidencialidad y Roles:** * Cuando un enfermero o médico intenta abrir un historial, el componente IAM valida la **relación de asignación** (¿Es este paciente parte de su cupo/disponibilidad?). Si la respuesta es no, el acceso se deniega automáticamente.
 - **Control de Umbrales:** El sistema expone el endpoint POST /config/thresholds protegido exclusivamente para usuarios con el rol Médico. Si un usuario con rol Enfermería intenta modificarlo, el API Gateway rechaza la petición con un error 403 Forbidden.

Flujo 4: Registro de Actividad (Petición del Director)

- **Cómo se comunican:** De manera asíncrona mediante un bus de eventos (como Kafka) para no ralentizar el sistema.
- **Cumplimiento de Auditoría:** Cada vez que el API Gateway procesa una solicitud de "Lectura de Historial", envía un evento al **Módulo de Auditoría**. Este log guarda: *ID del usuario, Rol, ID del paciente, Fecha/Hora y Acción realizada*.
 - *Nota de seguridad:* Estos logs se envían a un almacenamiento de tipo **WORM** (*Write Once, Read Many*), asegurando que nadie (ni siquiera un administrador del sistema o un atacante que haya escalado privilegios) pueda borrar el rastro de quién consultó un historial.

Este diseño equilibra perfectamente la agilidad médica en caso de emergencia con las restricciones estrictas de privacidad y control que requiere un sistema de salud moderno.

User prompt: Prioriza los componentes del sistema en cuanto a su criticidad

Response: Como ingeniero de seguridad, para priorizar la criticidad de los componentes aplico un análisis basado en el **impacto en la vida del paciente** (Seguridad Física/Disponibilidad) e **impacto legal y reputacional** (Confidencialidad e Integridad de Datos Médicos).

Clasificaremos los componentes en tres niveles de criticidad: **Crítico (Tier 1)**, **Alto (Tier 2)** y **Operacional (Tier 3)**.

1. Nivel Crítico (Tier 1): Impacto Vital Inmediato

Si cualquiera de estos componentes falla o es vulnerado, **la vida del paciente corre peligro inminente** o se rompe la regla de oro de la confidencialidad médica desde el primer segundo.

- **Motor de Reglas y Alertas de Emergencia:** Es el componente más crítico. Si este módulo se cae o sufre un retraso (*delay*), un paciente con una hipoglucemia o hiperglucemia severa no recibirá asistencia médica a tiempo. Su disponibilidad debe ser del 99.999% (cinco nueves).
- **Servicio de Identidad y Acceso (IAM):** Controla las autorizaciones (ABAC/RBAC). Si este componente falla de forma "abierta", cualquiera podría ver los datos de cualquier paciente (violación masiva de privacidad). Si falla de forma "cerrada", los médicos no

podrán ver los datos para tratar una emergencia.

- **Sensor IoT y App Móvil (Módulo de Detección de Umbrales):** La capacidad de la app para procesar el dato cada 10 minutos y decidir saltarse el envío diario para lanzar una alerta inmediata es vital. Si la app se congela o el sensor transmite datos corruptos (fallo de integridad), el sistema central queda ciego.

2. Nivel Alto (Tier 2): Impacto Legal y Continuidad del Tratamiento

Un fallo aquí no matará a un paciente en los próximos 10 minutos, pero generará **sanciones legales multimillonarias (como RGPD)**, pérdida de confianza total o incapacidad de realizar el seguimiento médico diario.

- **Módulo de Auditoría y Logs Inmutables (WORM):** Es la garantía exigida por la dirección. Si un atacante o un empleado malintencionado puede acceder a los historiales y borrar los logs de acceso, el hospital pierde la capacidad de demostrar el cumplimiento legal y forense. Debe ser altamente íntegro y protegido contra modificaciones.
- **Base de Datos Clínica (Cifrada):** Almacena el histórico. Su criticidad es alta en cuanto a confidencialidad (cifrado) e integridad. Si se corrompe, el personal médico pierde el histórico de la evolución del paciente, afectando a las decisiones de tratamiento a largo plazo.
- **API Gateway (Endpoint de Configuración de Umbrales):** Este punto específico debe estar ultra protegido. Si un atacante logra saltarse el control y modificar los umbrales de los pacientes, podría provocar que nunca se disparen las alarmas de emergencia o, por el contrario, colapsar el centro de emergencias con falsos positivos.

3. Nivel Operacional (Tier 3): Eficiencia y Rutina

Componentes necesarios para el funcionamiento del día a día, pero cuyo fallo temporal (horas) es tolerable y gestionable mediante procedimientos de contingencia tradicionales.

- **Servicio de Ingesta Diaria (Volcado de datos):** Si el envío que se realiza una vez al día falla debido a problemas de red, los datos se quedan guardados de forma segura en la app del paciente y se reintentará el envío más tarde. No interrumpe la sincronización de alertas críticas del Tier 1.
- **Interfaz de Usuario del Personal (Frontend del Hospital):** Si la aplicación web que usan las enfermeras o médicos se cae, el personal puede recurrir temporalmente a planes de contingencia (como consultar al servicio técnico de guardia para consultas directas a la base de datos o llamadas telefónicas).

Resumen de Priorización para el Plan de Mitigación

Componente	Criticidad	Enfoque de Seguridad Principal
Motor de Alertas / Emergencias	 Crítico (Tier 1)	Alta Disponibilidad y Tolerancia a Fallos

Componente	Criticidad	Enfoque de Seguridad Principal
Servicio de Identidad y Acceso (IAM)	🔥 Crítico (Tier 1)	Control de Accesos Estricto (Menor Privilegio)
Sensor e Inteligencia de la App	🔥 Crítico (Tier 1)	Integridad del Dato y Cifrado Extremo a Extremo
Módulo de Auditoría (Logs)	⚠️ Alto (Tier 2)	Inmutabilidad (No Modificable/No Borrable)
Base de Datos Clínica	⚠️ Alto (Tier 2)	Cifrado en Reposo y Copias de Seguridad
API Gateway (Gestión de Umbrales)	⚠️ Alto (Tier 2)	Autenticación Robusta y Filtrado de Peticiones
Servicio de Ingesta Diaria / Frontend	🟢 Operacional (Tier 3)	Resiliencia y Recuperación Post-Caída

User prompt: Haz un análisis de amenazas STRIDE para los sistemas identificados en la tabla anterior. Para cada una de los tipos STRIDE identifica al menos tres amenazas diferentes

Response: Para realizar un análisis **STRIDE** riguroso, evaluaremos las amenazas específicas sobre los componentes que identificamos en la tabla de criticidad. STRIDE representa seis categorías de riesgos de seguridad: **Spoofing** (Suplantación), **Tampering** (Manipulación), **Repudiation** (Repudio), **Information Disclosure** (Fuga de información), **Denial of Service** (Denegación de servicio) y **Elevation of Privilege** (Elevación de privilegios).

A continuación, se detallan tres amenazas diferentes para cada una de las categorías del modelo, enfocadas en nuestro ecosistema médico.

1. Spoofing (Suplantación de identidad)

Esta amenaza ataca la **autenticidad** del sistema, haciéndose pasar por un usuario, dispositivo o componente legítimo.

- **Amenaza 1 (Sensor/App):** Un atacante utiliza un dispositivo Bluetooth malicioso para suplantar el sensor IoT legítimo del paciente y enviar lecturas de glucosa falsas a la aplicación móvil.
- **Amenaza 2 (Médico/Backend):** Un atacante roba las credenciales de un médico (mediante un ataque de *phishing*) y se autentica en el sistema del hospital para consultar historiales médicos de pacientes que no tiene asignados.
- **Amenaza 3 (API Gateway):** Un servicio malicioso externo suplanta la identidad del Servidor de Emergencias mediante un ataque de envenenamiento de DNS, logrando que el Motor de Alertas le envíe a él las notificaciones críticas en lugar de al centro de salud real.

2. Tampering (Manipulación de datos)

*Esta amenaza ataca la **integridad** de los datos, modificando la información en tránsito o en reposo.*

- **Amenaza 1 (App/Gateway):** Un atacante intercepta el tráfico de red de la aplicación móvil (mediante un ataque *Man-in-the-Middle*) y modifica los valores de azúcar antes de que lleguen al Servicio de Ingesta Diaria para falsear el expediente.
- **Amenaza 2 (Base de Datos):** Un empleado del hospital con acceso local o un atacante que vulneró la red interna modifica directamente los registros de la Base de Datos Clínica para alterar el umbral de alerta de un paciente específico, inhabilitando las alarmas vitales.
- **Amenaza 3 (Firmware del Sensor):** Manipulación física o remota del firmware del sensor IoT aprovechando una vulnerabilidad de actualización de software no firmada, forzándolo a reportar siempre niveles de glucosa normales.

3. Repudiation (Repudio)

*Esta amenaza ataca la **trazabilidad y el no repudio**, permitiendo que un usuario niegue haber realizado una acción porque el sistema no puede probarlo.*

- **Amenaza 1 (Médico/Umbrales):** Un médico modifica erróneamente el umbral de alerta de un paciente hacia un límite peligroso. Tras un incidente médico, el profesional niega haber realizado dicha modificación porque el sistema no registra el origen exacto del cambio o permite borrar los logs locales.
- **Amenaza 2 (Enfermería/Acceso):** Un miembro del personal de enfermería accede al historial clínico de una celebridad ingresada en el hospital por curiosidad y posteriormente niega haberlo hecho, aprovechando que el sistema utiliza una cuenta genérica o compartida en los terminales de planta.
- **Amenaza 3 (Módulo de Logs):** Un administrador del sistema malintencionado accede a la Base de Datos Clínica y, posteriormente, manipula o borra las líneas correspondientes del Módulo de Auditoría para eliminar cualquier rastro de su intrusión.

4. Information Disclosure (Fuga de información)

*Esta amenaza ataca la **confidencialidad** de los datos, exponiendo información sensible a personas no autorizadas.*

- **Amenaza 1 (Base de Datos):** Robo o filtración de las copias de seguridad (*backups*) de la Base de Datos Clínica debido a que se almacenaban en un servidor de archivos compartido o en la nube sin cifrar.
- **Amenaza 2 (App Móvil):** La aplicación móvil del paciente almacena el histórico de glucosa en el almacenamiento local del teléfono de forma interna en texto plano; un malware instalado en el dispositivo del paciente extrae y expone estos datos de salud.
- **Amenaza 3 (Red del Hospital):** Un atacante realiza un análisis de tráfico (*sniffing*) dentro de la red local del hospital y captura los datos de salud de los pacientes en tránsito porque la comunicación entre el API Gateway y las terminales internas usa HTTP en lugar

de HTTPS.

5. Denial of Service (Denegación de servicio)

*Esta amenaza ataca la **disponibilidad** del sistema, impidiendo que los usuarios legítimos accedan a los servicios.*

- **Amenaza 1 (API Gateway/Motor de Alertas):** Un ataque de denegación de servicio distribuido (DDoS) satura el API Gateway con peticiones basura, bloqueando la entrada de los paquetes de **Alerta Inmediata** enviados por las apps de los pacientes en estado crítico.
- **Amenaza 2 (Sensor/App):** Un atacante genera interferencias intencionadas en el espectro de radiofrecuencia de 2.4 GHz (inhibidor de señal), impidiendo de manera persistente la comunicación BLE entre el sensor IoT y la aplicación móvil del paciente.
- **Amenaza 3 (Base de Datos):** Un atacante envía consultas de búsqueda masivas y extremadamente complejas al sistema del historial clínico, consumiendo toda la CPU y memoria de la Base de Datos Clínica y dejando al personal médico sin acceso al sistema durante horas.

6. Elevation of Privilege (Elevación de privilegios)

*Esta amenaza ataca la **autorización**, permitiendo que un usuario obtenga más permisos de los que legalmente le corresponden.*

- **Amenaza 1 (Enfermería/IAM):** Un usuario con el rol de Enfermería aprovecha una vulnerabilidad de inyección SQL o de asignación masiva de parámetros (*Mass Assignment*) en el API Gateway para cambiar su rol a Médico y ganar la capacidad de modificar los umbrales de alerta.
- **Amenaza 2 (Paciente/App):** Un paciente avanzado (*cracker*) manipula los tokens de sesión (JWT) generados por el backend, alterando el campo de identidad para hacerse pasar por el administrador del hospital y obtener control total sobre la plataforma.
- **Amenaza 3 (Personal Técnico/Sistema):** Un técnico de soporte de nivel básico del hospital explota una vulnerabilidad local de desbordamiento de búfer (*Buffer Overflow*) en el sistema operativo del servidor de auditoría, obteniendo permisos de Root (superusuario) sobre los logs inmutables.

Resumen de mitigación recomendada para el diseño

Para blindar el sistema frente a este mapa de amenazas STRIDE, el plan de ingeniería debe incluir de forma obligatoria:

1. **Autenticación mutua (mTLS)** y cifrado de extremo a extremo.
2. **Tokens JWT firmados y cifrados** con validación estricta de scopes para evitar la elevación de privilegios.
3. **Módulo de Auditoría WORM** en un entorno aislado de la red principal.
4. **Validación estricta de esquemas de datos** en el API Gateway para evitar inyecciones y

User prompt: Presenta los resultados en forma de tabla

Response: Aquí tienes el análisis de amenazas **STRIDE** organizado en una matriz técnica estructurada. Esta disposición permite correlacionar de un vistazo cada tipo de amenaza con el componente específico afectado, el impacto real en el sistema y la contramedida de ingeniería de seguridad que se debe aplicar.

Categoría STRIDE	#	Componente Afectado	Descripción de la Amenaza	Impacto Potencial	Contramedida
Spoofing (Suplantación)	1	Sensor IoT / App	Dispositivo pirata suplanta al sensor legítimo vía Bluetooth enviando lecturas falsas.	Diagnósticos erróneos o alertas médicas falsas.	Emparejamiento mediante <i>Number Comparison</i> y cifrado criptográficas ú sensor.
	2	Backend / IAM	Robo de credenciales médicas mediante <i>phishing</i> para ingresar al sistema central.	Acceso no autorizado a Datos de Salud Protegidos (PHI).	Autenticación M (MFA) obligatorio condicional bas Ubicación.
	3	API Gateway	Envenenamiento de DNS desvía el tráfico de alertas hacia un servidor malicioso externo.	Pérdida de alertas críticas y fuga masiva de datos en tiempo real.	Implementación y uso de mTLS con validación certificados.
Tampering (Manipulación)	1	Canal de Ingesta (Red)	Ataque <i>Man-in-the-Middle</i> (MitM) que altera los valores de glucosa en tránsito antes de llegar al hospital.	Alteración del historial clínico permanente del paciente.	Uso obligatorio con <i>Certificate</i> integrado en el aplicación móvi
	2	Base de Datos Clínica	Modificación directa en la base de datos de los umbrales de alerta de un paciente.	Desactivación silenciosa de alertas vitales para el paciente.	Firmado cripto registros sensiti (<i>chaining</i>) y cifrado (TDE).

Categoría STRIDE	#	Componente Afectado	Descripción de la Amenaza	Impacto Potencial	Contramedida
	3	Firmware del Sensor	Inyección de software malicioso aprovechando una actualización de firmware no verificada.	Secuestro del dispositivo médico o envío de datos estáticos normales.	Firma digital ob todo firmware n criptografía asir verificada por h (<i>Secure Boot</i>).
Repudiation (<i>Repudio</i>)	1	API Gateway / Médicos	Un médico cambia un umbral por error, ocurre un incidente y niega haber sido el autor.	Imposibilidad de determinar responsabilidades legales ante negligencias.	Logs firmados c por el ID del tol en cada transac cambio.
	2	Terminales de Planta	Personal de enfermería consulta el historial de una celebridad y niega la acción.	Violación de privacidad sin autor detectable; multas por normativas de salud.	Prohibición de c genéricas; cierr automático por autenticación b tarjeta.
	3	Módulo de Auditoría	Un administrador con privilegios altera las líneas de logs para borrar el rastro de su intrusión.	Pérdida absoluta de la confianza forense del sistema informático.	Almacenamient un entorno WO Once, Read Me en tiempo real t entorno local.
Information Disclosure (<i>Fuga de Datos</i>)	1	Servidor de Backups	Robo de copias de seguridad de la base de datos clínica que se guardaban sin protección.	Exposición masiva de historiales médicos en el mercado negro.	Cifrado obligat los <i>backups</i> co gestionadas en (Módulo de Seq Hardware).
	2	Almacenamiento Móvil	La app guarda el histórico de glucosa en el almacenamiento local del teléfono en texto plano.	Aplicaciones maliciosas (<i>malware</i>) en el móvil pueden extraer la salud del paciente.	Uso de almace cifrado nativo d (<i>EncryptedSha</i> / <i>SQLite cipher</i>).
	3	Red del Hospital (LAN)	Captura de paquetes (<i>sniffing</i>) dentro de la red interna	Exposición de datos médicos a cualquier intruso conectado a la	Cifrado de extre dentro del centi (cero confianza <i>Network</i>).

Categoría STRIDE	#	Componente Afectado	Descripción de la Amenaza	Impacto Potencial	Contramedida
Denial of Service (Denegación)			porque el tráfico viaja en HTTP plano.	red local del hospital.	
	1	API Gateway	Ataque de denegación de servicio distribuido (DDoS) satura la entrada de la API del hospital.	Bloqueo absoluto de la recepción de alertas de emergencia de los pacientes.	Implementación <i>Limiting</i> estricto Dispositivo y perímetro avar Cloud Scrubbin
	2	Sensor IoT (Espectro)	Uso de un inhibidor de frecuencias en el entorno del paciente para bloquear la señal de 2.4 GHz.	Aislamiento del sensor; el paciente queda desprotegido ante variaciones de azúcar.	Alertas locales visuales en el n desconexión cc supera los 20 n
Elevation of Privilege (Elevación)	3	Base de Datos Clínica	Inyección de consultas SQL masivas y complejas que saturan el uso de CPU del servidor.	Caída del sistema informático del hospital; médicos y enfermeras sin acceso a historiales.	Optimización de separación de l datos de lectura tiempos de esp ejecución (<i>time</i>
	1	API Gateway / Código	Explotación de vulnerabilidad de asignación masiva de parámetros para cambiar el rol de Enfermería a Médico.	Personal no cualificado modificando umbrales críticos de alerta de salud.	Validación estricta de entrada (<i>Wh</i> verificación de backend en base inmutables.
	2	Aplicación / Autenticación	Manipulación de los parámetros de los tokens de sesión (JWT) cambiando el ID del usuario por el de Admin.	Control total del atacante sobre la configuración global del hospital.	Firma de token: mediante algoritmos asimétricos rob con verificación clave pública.

Categoría STRIDE	#	Componente Afectado	Descripción de la Amenaza	Impacto Potencial	Contramedida
	3	Servidor de Auditoría	Explotación de un desbordamiento de búfer en el sistema operativo del servidor de logs.	Acceso raíz (<i>Root</i>) del atacante para apagar los sistemas de control y monitorización.	Parcheo y actu. automatizada d operativos; min superficie de at (<i>Hardening</i>).

User prompt: Prioriza las amenazas de la tabla anterior atendiendo a la criticidad del sistema al que afectan

Response: Para priorizar las amenazas del análisis STRIDE, cruzaremos la tabla anterior con la **matriz de criticidad de componentes** que definimos al inicio. El criterio fundamental de la ingeniería de seguridad en salud es: **Cualquier amenaza que afecte a la disponibilidad de las alertas o a la integridad del control de accesos se sitúa en la cima de la pirámide de riesgo (Prioridad Muy Alta)**, ya que impacta de forma directa en la vida del paciente.

A continuación, se presentan las amenazas priorizadas y organizadas por niveles de acción inmediata.

Prioridad 1: Amenazas Críticas (Afectan a Componentes Tier 1)

Estas amenazas combinan un impacto directo en la salud del paciente (pérdida de alertas de emergencia) o una vulneración total de la confidencialidad en el punto de entrada. Requieren mitigación obligatoria antes del despliegue.

A. Bloqueo de Alertas Médicas (Impacto: Disponibilidad / Vida del Paciente)

- **DoS-1 (Ataque DDoS al API Gateway):** Si un atacante inunda el gateway, las apps de los pacientes no pueden enviar los paquetes de "Alerta Inmediata". Un paciente en shock glucémico no sería detectado por el hospital.
- **DoS-2 (Inhibición de señal BLE del Sensor):** Si se bloquea la frecuencia de 2.4 GHz en casa del paciente, el móvil se queda sin datos. Aunque el backend funcione, el sistema está ciego en origen.

B. Vulneración del Control de Accesos (Impacto: Confidencialidad / Autenticidad)

- **Spoofing-2 (Phishing de credenciales médicas en el IAM):** El robo de una cuenta médica legítima da acceso directo a ver el historial completo y en tiempo real de múltiples pacientes asignados, rompiendo la confidencialidad exigida.
- **Spoofing-1 (Suplantación del Sensor IoT):** Si un atacante inyecta lecturas falsas simulando ser el sensor, puede provocar que el Motor de Reglas dispare alertas de

emergencia falsas continuamente (colapsando el servicio) o que camufle una crisis real enviando datos normales.

Prioridad 2: Amenazas Altas (Afectan a Componentes Tier 2)

Estas amenazas comprometen la integridad de los datos a largo plazo, la configuración del sistema médico o la capacidad legal del hospital para auditar accesos (petición del director).

A. Modificación de Reglas Clínicas (Impacto: Integridad del Tratamiento)

- **Tampering-2 (Modificación de umbrales en Base de Datos):** Si alguien altera los límites de alerta directamente en la base de datos, el Motor de Reglas procesará datos reales pero bajo reglas falsas, inhabilitando las alarmas.
- **Elevation-1 y Elevation-2 (Elevación de privilegios en API/JWT):** Si un rol de enfermería (o un agente externo) escala privilegios a rol de médico, gana la capacidad ilegal de reconfigurar los umbrales de alerta del sistema.

B. Destrucción de la Trazabilidad y Fugas Masivas (Impacto: Cumplimiento Legal y Privacidad)

- **Repudiation-3 (Borrado de Logs de Auditoría):** Si un atacante o usuario interno puede eliminar sus huellas del módulo de logs, el director del hospital nunca podrá saber quién accedió de forma ilegítima a un historial clínico.
- **Information Disclosure-1 (Robo de Backups sin cifrar):** Expone la base de datos histórica completa en un solo ataque, lo que conlleva penalizaciones severas bajo normativas como el RGPD.

Prioridad 3: Amenazas Operacionales (Afectan a Componentes Tier 3)

Tienen un impacto acotado. No ponen en peligro inmediato la vida del paciente ni destruyen las capacidades de auditoría del sistema, y existen planes de contingencia manuales para mitigar su efecto temporal.

A. Interrupción del Día a Día (Impacto: Eficiencia del Hospital)

- **DoS-3 (Saturación de consultas en la Base de Datos):** Ralentiza o tumba la interfaz visual que usan los médicos en sus ordenadores. Es problemático, pero el personal puede seguir llamando por teléfono a emergencias o atender usando los datos que lleguen directamente a los terminales de guardia.
- **Tampering-1 (MitM en la Ingesta Diaria):** Modificar el volcado de datos diario altera el histórico del expediente, pero la alerta en tiempo real (Tier 1) ya habría funcionado de manera independiente a través del canal de emergencia.

B. Fugas de Información Locales (Impacto: Privacidad Individualizada)

- **Information Disclosure-2 (Extracción de datos del almacenamiento del móvil):** Es un riesgo alto para ese paciente específico si su móvil es hackeado, pero el impacto está acotado a un único usuario y no compromete la infraestructura central del hospital.

Resumen Ejecutivo de Mitigación por Fases

Para el equipo de desarrollo, la hoja de ruta de implementación de seguridad se debe ejecutar estrictamente en este orden:

1. **Fase 1 (Inmediata):** Implementar las contramedidas contra **DDoS** en el Gateway, robustecer el **MFA** en el IAM y asegurar el **cifrado/autenticación BLE** del sensor.
 2. **Fase 2 (Antes de producción):** Desplegar el almacenamiento **WORM** para los logs, cifrar los backups de la base de datos y aplicar validación estricta de firmas en los tokens **JWT**.
 3. **Fase 3 (Mejora continua):** Securitizar el almacenamiento local de la app móvil y optimizar las consultas de la base de datos clínica para evitar bloqueos por sobrecarga.
-

User prompt: Prioriza las amenazas según la probabilidad estimada de explotación

Response: Para priorizar las amenazas según su **probabilidad estimada de explotación**, un ingeniero de seguridad evalúa factores del mundo real: la superficie de exposición (si el componente da a Internet o es interno), la motivación del atacante, la complejidad técnica necesaria para ejecutar el ataque y la existencia de herramientas automatizadas que faciliten la intrusión.

Bajo este criterio, las amenazas se reorganizan de una forma muy distinta a la criticidad por impacto. Los ataques dirigidos a los eslabones más débiles (usuarios humanos y aplicaciones móviles) suben a la cima, mientras que los ataques físicos o de ingeniería ultra-compleja bajan en la lista.



Nivel 1: Probabilidad Alta (Exposición Constante y Automatizada)

Son los vectores de ataque más probables. No requieren que el atacante esté físicamente cerca del hospital ni del paciente, y se apoyan en herramientas automatizadas de escaneo o ingeniería social masiva.

- **Spoofing-2 (Phishing para robo de credenciales médicas): La amenaza más probable.** Los humanos son el eslabón más débil. Los ataques de phishing dirigidos a personal sanitario para robar credenciales de acceso a sistemas internos ocurren a diario en el sector salud a nivel global.
- **DoS-1 (Ataque DDoS al API Gateway):** El API Gateway del hospital está expuesto públicamente a Internet para recibir los datos de las aplicaciones móviles. Esto lo convierte en un blanco fácil para botnets que buscan extorsionar al hospital o interrumpir el servicio mediante denegación de servicio.
- **Information Disclosure-2 (Malware extrayendo datos del móvil del paciente):** Los smartphones de los usuarios finales son entornos muy inseguros. La probabilidad de que

un paciente instale una aplicación maliciosa (un juego infectado, por ejemplo) que intente leer el almacenamiento local de otras apps es considerablemente alta.



Nivel 2: Probabilidad Media (Requiere Intrusión o Conocimiento Interno)

Ataques que exigen que el delincuente ya haya superado una primera barrera de defensa (como la red perimetral) o que posea conocimientos específicos sobre la infraestructura del hospital.

- **Elevation-1 y Elevation-2 (Manipulación de APIs / Tokens JWT):** Si un atacante (o un empleado descontento) ya tiene un acceso básico al sistema del hospital, buscará de forma activa "saltar" de un rol de enfermería a uno médico mediante la manipulación de variables en las peticiones HTTP para ganar control sobre los umbrales.
- **DoS-3 (Saturación de la Base de Datos Clínica):** Explotar consultas ineficientes para tumbar el sistema requiere entender cómo funciona la aplicación interna del hospital o tener la capacidad de enviarle peticiones masivas desde dentro de la red.
- **Information Disclosure-1 (Robo de Backups sin cifrar):** Generalmente ocurre por errores de configuración de los administradores de sistemas (por ejemplo, dejar un bucket de almacenamiento en la nube configurado como "público"). Es un error común en la industria.
- **Repudiation-2 (Uso de cuentas compartidas en Terminales de Planta):** En el caos del día a día de un hospital, es muy común que el personal olvide cerrar sesión o use la cuenta del compañero para agilizar el trabajo, lo que destruye de forma indirecta la trazabilidad de los accesos.



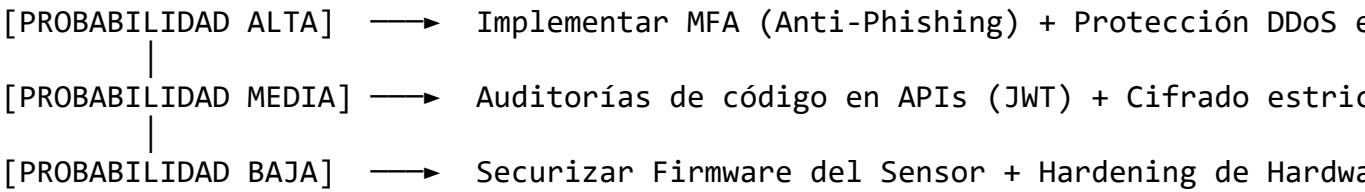
Nivel 3: Probabilidad Baja (Requiere Proximidad Física o Alta Complejidad)

Ataques que requieren recursos extraordinarios, presencia física en el entorno del paciente o del hospital, o un nivel de ingeniería inversa de hardware extremadamente avanzado.

- **Spoofing-1 y DoS-2 (Suplantación y bloqueo del Sensor por Bluetooth):** Para hackear o inhibir el Bluetooth (BLE) del paciente, el atacante debe estar físicamente a menos de 10 o 15 metros de la víctima (en su casa o en la calle). Esto reduce la probabilidad a casos de ataques dirigidos muy específicos (como espionaje o sabotaje personal).
- **Tampering-3 (Manipulación del Firmware del Sensor):** Exige extraer el firmware del glucómetro, encontrar una vulnerabilidad de día cero (Zero-Day), evadir las protecciones físicas del chip y empaquetar una actualización maliciosa. El esfuerzo técnico es masivo.
- **Repudiation-3 (Modificación de Logs de Auditoría por un Admin):** Los administradores de sistemas suelen estar estrictamente supervisados. Alterar los logs de auditoría sin dejar un rastro secundario en otros sistemas de red es técnicamente muy complejo para un solo individuo.

Matriz de Priorización por Probabilidad

Organizar el plan de mitigación bajo esta perspectiva permite enfocar el presupuesto y los esfuerzos de desarrollo en lo que **con mayor certeza va a ocurrir primero**.



Prioridad de Implementación	Categoría STRIDE Relacionada	Foco de Defensa Técnico
1. Inmediata (Probabilidad Alta)	Spoofing (Credenciales), DoS (Red), Information Disclosure (Móvil).	Proteger la identidad humana (MFA), robustecer el perímetro expuesto a Internet y aislar la app móvil.
2. Secundaria (Probabilidad Media)	Elevation of Privilege, Tampering (BBDD), Repudiation (Terminales).	Realizar pruebas de penetración (PenTesting) en las APIs y aplicar políticas estrictas de bloqueo de terminales.
3. A Largo Plazo (Probabilidad Baja)	Tampering (Firmware), DoS (Espectro Radio), Repudiation (Logs).	Implementar ciclos de desarrollo de hardware seguro (Secure Lifecycle) y auditorías de configuración de infraestructura.

User prompt: Prioriza las amenazas STRIDE identificadas en el sistema que has diseñado basándose en su criticidad y su probabilidad de explotación. Presenta los resultados en forma de tabla.

Response: Para obtener una visión realista del riesgo, un ingeniero de seguridad debe cruzar ambas variables. La **criticidad** (el impacto en el paciente/hospital) y la **probabilidad de explotación** (la facilidad para el atacante) se combinan para calcular el **Nivel de Riesgo Global** utilizando la clásica fórmula de gestión de riesgos:

Riesgo = Criticidad (Impacto) × Probabilidad

A continuación, presento la priorización unificada de las 18 amenazas STRIDE identificadas para tu sistema médico, ordenadas de **Mayor Riesgo Global** a **Menor Riesgo Global**.

Matriz de Priorización de Riesgo STRIDE (Combinada)

- **Riesgo Crítico:** Requiere mitigación inmediata antes de que el sistema reciba cualquier dato real.
- **Riesgo Alto:** Debe mitigarse en las primeras fases del desarrollo.
- **Riesgo Medio/Bajo:** Se gestiona mediante políticas operacionales o parches progresivos.

#	Categoría STRIDE	Componente Afectado	Descripción Corta de la Amenaza	Criticidad (Impacto)	Probabilidad de Explotación	Nivel Riesgo Global
1	Denial of Service	API Gateway	Ataque DDoS que satura el Gateway bloqueando alertas críticas.	 Alta (Tier 1)	 Alta	 CRÍTICO
2	Spoofing	Backend / IAM	<i>Phishing</i> de credenciales médicas para acceder a historiales.	 Alta (Tier 1)	 Alta	 CRÍTICO
3	Elevation of Privilege	API Gateway	Modificación de peticiones para pasar de Enfermería a Médico.	 Alta (Tier 2)	 Alta	 CRÍTICO
4	Elevation of Privilege	Autenticación	Manipulación de parámetros de tokens JWT (identidad Admin).	 Alta (Tier 2)	 Alta	 CRÍTICO
5	Spoofing	Sensor IoT / App	Dispositivo BLE pirata inyecta lecturas falsas de azúcar.	 Alta (Tier 1)	 Media	 ALTO
6	Information Disclosure	Almacenamiento Móvil	<i>Malware</i> en el móvil extrae datos de salud de la app.	 Operacional	 Alta	 ALTO
7	Tampering	Base de Datos	Modificación directa de los umbrales de alerta clínicos.	 Alta (Tier 2)	 Media	 ALTO
8	Information Disclosure	Servidor Backups	Robo de copias de seguridad históricas no cifradas.	 Alta (Tier 2)	 Media	 ALTO
9	Repudiation	Terminales Planta	Acceso ilegítimo usando sesiones abiertas/ compartidas.	 Alta (Tier 2)	 Alta	 ALTO

#	Categoría STRIDE	Componente Afectado	Descripción Corta de la Amenaza	Criticidad (Impacto)	Probabilidad de Explotación	Nivel Riesgo Global
10	Denial of Service	Sensor IoT / BLE	Uso de inhibidor de frecuencias en el entorno del paciente.	🔥 Alta (Tier 1)	📉 Baja	🟡 MEDIO
11	Spoofing	API Gateway	Envenenamiento DNS desvía alertas a servidor externo.	🔥 Alta (Tier 1)	📉 Baja	🟡 MEDIO
12	Tampering	Canal de Ingesta	Ataque MitM que altera datos del volcado diario en tránsito.	🟢 Operacional	📊 Media	🟡 MEDIO
13	Denial of Service	Base de Datos	Inyección de consultas SQL pesadas que tumban el sistema.	🟢 Operacional	📊 Media	🟡 MEDIO
14	Repudiation	API Gateway	Un médico cambia un umbral erróneamente y lo niega.	⚠️ Alta (Tier 2)	📉 Baja	🟡 MEDIO
15	Information Disclosure	Red Hospitalaria	<i>Sniffing</i> de datos de salud en tránsito local por HTTP plano.	⚠️ Alta (Tier 2)	📉 Baja	🟡 MEDIO
16	Tampering	Firmware Sensor	Modificación del código interno del chip del glucómetro.	🔥 Alta (Tier 1)	📉 Baja	🟡 MEDIO
17	Repudiation	Módulo Auditoría	Un administrador borra líneas de logs para ocultar su rastro.	⚠️ Alta (Tier 2)	📉 Baja	🟡 MEDIO
18	Elevation of Privilege	Servidor Auditoría	Explotación de <i>Buffer Overflow</i> para ganar acceso Root.	⚠️ Alta (Tier 2)	📉 Baja	🟢 BAJO

Conclusiones del Análisis de Riesgo

1. **El peligro de las "Puertas Traseras" lógicas (Riesgo Crítico):** Las amenazas de **Elevación de Privilegios (#3 y #4)** se posicionan en lo más alto. Aunque conceptualmente no detienen el envío de una alerta como un DDoS, su probabilidad es muy alta debido a la automatización de herramientas de hacking de APIs. Si un atacante altera los JWT, toma el control total del backend médico.
 2. **El factor humano y perimetral (Riesgo Crítico/Alto):** El **Phishing (#2)** y el **DDoS (#1)** son certezas en el entorno actual de ciberseguridad hospitalaria. Al estar expuestos directamente a la acción humana y a Internet, la probabilidad satura el riesgo.
 3. **Los mitos de las amenazas de hardware (Riesgo Medio):** Modificar el **Firmware de un sensor (#16)** o usar un **Inhibidor de frecuencias (#10)** tiene una de las criticidades más altas del diseño (pueden causar la muerte del paciente por desinformación). Sin embargo, al requerir que el atacante persiga físicamente a un paciente en su día a día o tenga un laboratorio de ingeniería inversa microelectrónica, su riesgo real decae a "Medio" debido a su bajísima probabilidad de explotación masiva. Un hacker siempre preferirá atacar el API Gateway desde su casa que perseguir a un paciente por la calle.
-

User prompt: La dirección del hospital ha pedido una nueva funcionalidad: capacidad e hacer investigaciones científicas sobre los historiales clínicos anonimizados. Identifica una amenaza para cada una de los tipos STRIDE, prioriza las amenazas atendiendo a su criticidad y explotabilidad y presenta los resultados en forma de tabla

Response: Esta es una excelente e inevitable evolución para el sistema. Abrir una base de datos médica con fines de investigación científica (Big Data / Machine Learning) introduce una superficie de ataque completamente nueva. El mayor reto aquí es que **la anonimización total en salud es extremadamente difícil** debido a los ataques de correlación de datos.

Como ingeniero de seguridad, analizaremos las amenazas específicas de esta nueva funcionalidad científica utilizando el framework STRIDE, evaluando su criticidad e interés para un atacante.

1. Identificación de Amenazas STRIDE (Módulo de Investigación)

- **Spoofing (Suplantación):** Un atacante se hace pasar por un investigador universitario legítimo (robando sus credenciales o falseando su afiliación) para obtener acceso al portal de descarga de datos anonimizados.
- **Tampering (Manipulación):** Un actor malintencionado inyecta datos falsos o altera los registros del dataset de investigación para sesgar los resultados de un estudio científico (sabotaje farmacéutico o académico).
- **Repudiation (Repudio):** Un investigador extrae el dataset completo del hospital hacia un servidor externo no autorizado y el sistema no es capaz de demostrar qué científico realizó la descarga debido a la falta de firmas digitales en las peticiones de exportación.
- **Information Disclosure (Fuga de Información - Ataque de Reidentificación):** El atacante cruza el dataset "anonimizado" (que incluye fechas de nacimiento, códigos

postales y niveles de glucosa) con una base de datos pública (como el censo electoral o noticias locales). Al hacerlo, logra **reidentificar** a un paciente específico (ej. "Solo hay una persona de 65 años en este código postal que tuvo una crisis de glucosa el martes").

- **Denial of Service (Denegación de Servicio):** Un usuario lanza consultas analíticas masivas de inteligencia artificial (agregaciones pesadas, correlaciones complejas) directamente contra la base de datos de investigación, agotando los recursos del servidor y bloqueando el trabajo de los científicos.
- **Elevation of Privilege (Elevación de Privilegios):** Un usuario con rol de Investigador Externo (que solo debería ver datos agregados y anonimizados) explota una vulnerabilidad en la API de consultas para acceder a la base de datos de producción con privilegios de Médico, visualizando nombres, apellidos y DNI de los pacientes reales.

2. Matriz de Riesgo: Priorización de Amenazas Científicas

Para calcular el **Nivel de Riesgo Global**, recordamos la fórmula:

$$\text{Riesgo} = \text{Criticidad (Impacto)} \times \text{Probabilidad de Explotación}$$

En este escenario de investigación, **el impacto ya no es la muerte inmediata del paciente** (ya que no tocamos el Motor de Alertas en tiempo real), sino el **impacto legal catastrófico (RGPD)** y la pérdida de reputación si se viola la privacidad de miles de personas.

#	Categoría STRIDE	Componente/ Proceso Afectado	Descripción de la Amenaza	Criticidad (Impacto)	Probabilidad de Explotación	Nive Ries Glo
1	Information Disclosure	Dataset Anonimizado	Ataque de Reidentificación: Cruce de datos anonimizados con fuentes públicas para identificar pacientes reales.	 Alta (Multas multimillonarias y pérdida de reputación)	 Alta (Es el objetivo principal de los atacantes de datos masivos)	 CRÍ
2	Spoofing	Portal de Investigadores	Suplantación de la identidad de un científico para acceder al portal de datos.	 Media-Alta (Acceso a PHI masivo)	 Alta (<i>Phishing</i> o credenciales débiles)	 CRÍ
3	Elevation of Privilege	API de Consultas	Investigador explota vulnerabilidad para saltar a la BD de producción con nombres reales.	 Alta (Acceso a datos de pacientes reales)	 Media (Requiere descubrir un <i>exploit</i> en la API)	 ALT

#	Categoría STRIDE	Componente/ Proceso Afectado	Descripción de la Amenaza	Criticidad (Impacto)	Probabilidad de Explotación	Nive Ries Glot
4	Repudiation	Módulo de Exportación	Fuga de datasets por parte de un investigador sin que el hospital pueda probar quién fue.	⚠ Media (Pérdida de trazabilidad legal)	📈 Alta (Si no se implementa marca de agua o firma digital)	🔴 ALT
5	Denial of Service	Servidor Analítico	Consultas de Big Data masivas que saturan la base de datos de investigación.	🟢 Baja-Media (No afecta a las alertas médicas, solo a la ciencia)	📊 Media (Puede ocurrir incluso por error de los propios científicos)	🟡 MEC
6	Tampering	Pipeline de Datos	Manipulación de los datos del estudio para sabotear o alterar conclusiones científicas.	⚠ Media (Impacto reputacional en la investigación)	📉 Baja (Requiere motivación muy específica de sabotaje)	🟡 MEC

Recomendaciones de Ingeniería de Seguridad para la Dirección

Para mitigar las dos amenazas **Críticas** de esta nueva funcionalidad, debemos implementar tres defensas arquitectónicas antes de escribir la primera línea de código del módulo científico:

- 1. Privacidad Diferencial (Differential Privacy):** No basta con "borrar el nombre". Se debe inyectar ruido matemático controlado al dataset analítico. De este modo, los científicos pueden obtener patrones estadísticos globales precisos (ej. "El 20% de los pacientes de la región sufre hiperglucemia a las 4 PM"), pero es matemáticamente imposible revertir el dato para saber qué paciente específico sufrió la crisis.
 - 2. Arquitectura Aislada (Data Warehouse Independiente):** Jamás se permite a los investigadores lanzar consultas contra la base de datos donde operan los médicos. Se debe crear un proceso ETL (*Extract, Transform, Load*) que extraiga, limpie, anonimice y mude los datos una vez al mes a un entorno en la nube completamente aislado.
 - 3. Marcado de Agua Criptográfico (Data Watermarking):** Al exportar un dataset para un investigador, el archivo debe llevar una marca de agua invisible incrustada criptográficamente con el ID del investigador. Si el dataset se filtra en Internet, el hospital sabrá exactamente qué científico violó el acuerdo de confidencialidad.
-